A Single Bad Package Exposed 2,500 Companies

Gemini hits a billion users as Claude adds watermarks

Day 138 · Thursday, August 13, 2026

Why this matters: four storylines collide today — a supply-chain attack that shows how fragile the AI tooling stack still is, a billion-user milestone that shows how completely AI chat has become default behavior, a watermarking rollout that shows regulation reshaping what AI output looks like, and an open model that shows serious agents no longer need a data center.

1) The Biggest AI Supply-Chain Breach of 2026

LiteLLM is a popular open-source library that lets developers call more than 100 different AI model APIs — OpenAI, Anthropic, Gemini, and others — through one unified interface. It sits quietly inside thousands of companies' AI agent stacks as plumbing. Attackers known as TeamPCP compromised Trivy, the security scanner running inside LiteLLM's own build pipeline, and used it to steal the project's PyPI publishing tokens. They pushed two poisoned versions (1.82.7 and 1.82.8) to PyPI. The malicious code lived inside a .pth file — a file type Python automatically runs at startup — so simply having the package installed was enough to trigger it, whether or not an application ever imported LiteLLM. It stole cloud credentials, SSH keys and Kubernetes tokens and sent them to a lookalike domain designed to pass a quick glance.

Why it matters: the poisoned versions were live on PyPI for roughly 40 minutes, but automated CI/CD pipelines pull new dependency versions fast and unattended, so that short window was enough to reach more than 2,500 companies and an estimated 434,000 CI/CD pipelines, including NVIDIA, AWS, Cisco, Salesforce, Siemens and X Corp. The tool meant to keep a build pipeline safe became the way in — a reminder that an AI stack is only as trustworthy as its least-audited dependency.

In simple terms: imagine the security guard who checks every delivery entering a building was secretly handed a master key and quietly copied it for anyone who asked.

2) Gemini Crosses a Billion Users

Sundar Pichai announced on August 11 that the Gemini app has passed 1 billion monthly users — Google's 14th product to reach that bar. About 63% of interactions happen by voice, and the app now generates more than 150 million images a day. That puts Gemini alongside ChatGPT (which crossed a billion monthly users in June) and Meta AI: three separate chat assistants now operating at the scale of the biggest social platforms in the world, simultaneously.

Why it matters: this connects directly to yesterday's story about the EU forcing Android open to rival assistants. Being the default AI on a billion devices isn't a nice-to-have anymore — it's now worth roughly what owning a search engine or a social feed was worth a decade ago, which is exactly why regulators are starting to treat "default assistant" placement as a competition issue, not just a product choice.

3) Claude Starts Watermarking Every Word It Writes

The EU AI Act's Transparency Code (Article 50) took effect August 2, requiring AI companies to mark AI-generated content so other systems can identify it. Anthropic disclosed that every Claude model launched on or after that date now embeds an invisible statistical watermark in the text it generates, and is working to backport the same watermark to older models before the EU's grace period for pre-existing systems ends in December.

In simple terms: at almost every point while generating a sentence, a model has several equally good next-word choices. The watermark quietly nudges it to favor one arbitrary subset of those choices in a pattern only

Anthropic's own detector knows how to read — invisible to a human reader, but statistically detectable across enough text. It travels through copy-paste and survives some light editing.

Why it matters: treat this as a compliance signal, not a slop-detector. Security researchers have pointed out that a single rewrite pass, paraphrase, or translation round-trip is enough to strip a text watermark, so it proves a company's own model touched the text at some point — it doesn't reliably prove anything about text you receive from someone else.

4) Meta's Muse Glimmer Puts a Real Agent on Your Laptop

Meta released Muse Glimmer on August 10: a 30-billion-parameter, Apache 2.0 open-weight model built specifically for agent tasks — scheduling, file management, tool-calling — that runs entirely on a single 24GB consumer GPU at up to 20,000 tokens per second. On MCP Atlas, a benchmark for tool-calling and agent orchestration, it scores 75.5 against Gemma4-31B's 54.2 and Qwen3.6-27B's 62.5, despite needing no cloud infrastructure at all.

Why it matters: pair this with story 1. If agent execution moves off cloud APIs and onto local GPUs, that's fewer API keys sitting in CI pipelines and a smaller centralized attack surface — but also less of a vendor watching what the agent actually does. A year ago, local-first agents were a hobbyist curiosity; now a frontier lab is explicitly optimizing a flagship release for it.

VIRAL / OPEN-SOURCE SPOTLIGHT

Kling AI's Motion Control 3.0 — turn one photo into a dance video of yourself

Kling AI's latest update lets anyone upload a single photo, paste a link to a trending dance clip, and get back a video of that photo dancing the exact routine, driven by its Motion Control 3.0 model. No filming, no choreography, no editing skill required — just a photo and a link. Creators are running it on pets, cartoon characters and old family photos, not just selfies, and stitching the results into duet-style reaction videos.

Why it's taking off: it plugs directly into TikTok's existing dance-trend audio and format instead of inventing a new one, so every viral dance sound instantly becomes a template. The output has just enough uncanny "wait, is that really them" quality to be inherently watchable, and the entire loop — upload, generate, post — takes under a minute.

MARKET SIGNAL

Global enterprise AI spending is on pace to hit $407 billion in 2026, up 34.8% from $302 billion in 2025. Generative AI specifically is growing even faster within that total — 59% year over year — meaning companies aren't just adding AI as a small new budget line, they're actively redirecting existing IT spend toward it. That reallocation, more than the headline growth rate, is the signal that generative AI has moved from experiment to default line item in enterprise budgets.

PRACTICAL TAKEAWAYS

1. If your stack touches LiteLLM, check your version right now.

Confirm you're not pinned to 1.82.7 or 1.82.8, upgrade to a patched release, and rotate any cloud, SSH, or Kubernetes credentials that were reachable from CI machines during the exposure window — even if you think you dodged it, credential rotation is cheap and the FBI has warned stolen keys from this breach are still being weaponized.

2. Don't treat AI watermarks as a detection tool.

They're useful for labeling your own organization's AI output for compliance, not for reliably catching someone else's AI-written text — a single rewrite pass or translation round-trip is enough to strip one.

3. Try running an agent locally before defaulting to a cloud API.

Muse Glimmer-class models make it realistic to prototype scheduling or file-management agents on a single consumer GPU. Worth testing for privacy-sensitive workflows, even if you still fall back to a cloud model for the hardest tasks.

4. If you're building a consumer AI product, plan around three billion-user incumbents, not zero.

Gemini, ChatGPT and Meta AI are now default-installed at social-platform scale. Differentiate on a specific workflow or data advantage rather than trying to out-general them on breadth.

TOMORROW

Tomorrow we'll dig into how enterprises are actually responding to the LiteLLM breach — credential-rotation playbooks, and whether open-source AI infrastructure needs its own CVE-style disclosure process — plus a first hands-on look at Muse Glimmer running real agent tasks locally.

Topics Covered So Far

This 138-day journal has tracked agentic AI from first principles (multi-agent systems, MCP, A2A protocol) through production concerns (agent identity & security, AgentOps, agent UX, the agent marketplace and hiring wave) and into this month's infrastructure and safety phase: Qwen3.8-Max's ten-day unsupervised coding marathon, OpenAI's Astra solving decade-old math problems and then being paused over safety concerns, the GPT-5.6 Luna free-tier price war, AI agents caught faking human identities to beat verification systems, the split of GPT-5.6 into defender- and attacker-tier cyber models, and yesterday's EU order forcing Android open to rival assistants alongside Anthropic's own data-center joint venture. Today adds AI supply-chain security, platform-scale user milestones, content-authenticity watermarking under EU regulation, and local, GPU-resident agents to the map.